Entregable Semana 9 (AVZ9)

Consolidación del LLSD de R1, R2 y RE con análisis cuantitativo

Segunda parte

Grupo 3 — Horario H0892

TEL354: Redes Definidas por Software — 2026-2

31 de octubre de 2026

Coach	Germán Espinoza
Profesor	Christian Isaac Quispe Ordoñez
Integrantes	Rojas Soplin, Rodrigo Franco — 20213686 (líder)
	Oropeza León, Piero Jesús — 20212733 (arquitecto)
	Altamirano Ramírez, Camila Nicole — 20220964 (PM / QA)
	Tavella Rivero, Fernando Vincenzo — 20182693 (DevOps / SRE)
Archivo Paideia	AVZ9-TEL354_2026-2_G3

Cómo leer este documento

Este documento consolida el diseño de bajo nivel de la solución para los requisitos **R1** (control de acceso según rol), **R2** (protección de recursos privilegiados) y **RE** (eficiencia), y lo acompaña con su análisis cuantitativo: cada afirmación de diseño tiene su cifra, y cada cifra dice de dónde salió. Está escrito para leerse sin conocer los avances anteriores: la sección 2 presenta la solución completa, las secciones 3 a 21 detallan el diseño pieza por pieza —algoritmos, estados, contratos, matriz de acceso, configuración y secuencias completas—, las secciones 22 a 24 presentan los números, y la sección 25 los contrasta con el avance previo justificando cada ajuste.

1. La solución en una página

La solución es una red de campus gobernada por un controlador SDN, donde *quién puede qué* se decide en un punto central y se materializa como reglas concretas en los switches. El flujo de vida de una decisión es siempre el mismo: un dispositivo se conecta y recibe un **perfil mínimo (BASE)**; para salir de ese mínimo, la persona se autentica en un **portal cautivo**; el sistema de identidad determina *quién es* y *con qué rol*; el motor de políticas decide *qué puede*; el adaptador del controlador traduce la decisión a **reglas OpenFlow** con prioridades fijas; el switch las ejecuta y cuenta; y la auditoría registra todo.

Tres realidades definen el diseño. Primera: existen **tres reinos de identidad** — la comunidad universitaria se autentica contra el proveedor de identidad institucional; los operadores (TI, administradores, superadministradores) contra un repositorio propio de la plataforma con segundo factor obligatorio; y los invitados contra un registro efímero que se borra solo al vencer. Segunda: el tráfico se gobierna por una **escalera de prioridades** que es una jerarquía de autoridad — la mitigación manda sobre la sesión, la sesión sobre el perfil base, y el perfil base sobre los caminos. Tercera: la red se instala **de forma proactiva** — lo que se sabe que va a ocurrir (el perfil base, la sesión, la mitigación) se escribe en el switch de inmediato; el controlador solo se consulta para las tres excepciones cerradas: aprender un dispositivo nuevo, responder un ARP sin resolver y descubrir la topología.

Componente	Qué hace	Se comunica por
Portal cautivo	La única interfaz que ven las personas: elige el reino y pide credenciales; no decide nada	HTTP (personas); API REST (identidad)
Servicio de identidad	Verifica contra el reino elegido, emite la sesión con su rol y su vigencia, y la retira	REST · RADIUS · bus de eventos
Registro de dispositivos	Guarda qué equipos están habilitados y su historial; registrar no concede privilegios	REST · bus de eventos
Motor de políticas	El único punto de decisión: evalúa identidad, contexto y recurso, y ordena	REST · bus de eventos
Adaptador del controlador	Traduce cada orden a reglas OpenFlow con su prioridad, cookie y vencimiento	REST (northbound)
Controlador SDN	Clúster de tres nodos; mantiene la topología y aplica las reglas	OpenFlow (southbound)
Switches	Ejecutan y cuentan: conmutan sin depender del controlador	OpenFlow
Bus de eventos	Lo asíncrono: informa, no ejecuta	AMQP con colas durables
Auditoría	Registra todo lo que ocurre, sin excepción	Bus (escucha el catálogo completo)

2. Evolución del diseño: qué consolidó esta semana

El avance anterior dejó planteadas once cuestiones abiertas. Esta sección muestra cómo quedaron resueltas; es la evolución del diseño, no su repetición, y cada resolución cita la evidencia que la sostiene.

Cuestión abierta del avance previo	**Decisión consolidada**	**Evidencia**
£El switch soporta múltiples tablas y metadatos entre ellas?	Sí: 254 tablas disponibles (0–253). El pipeline de dos etapas puede materializarse en tablas físicas separadas	Sonda directa sobre el switch del laboratorio
£Cuál es la capacidad real de TCAM del switch?	No hay TCAM física: la conmutación es por software. El límite real de entradas se mide por llenado progresivo	Sonda; presupuesto en ğ24
£Cómo se redirige al portal?	La entrada de prioridad 150 del perfil base lleva al portal; el dispositivo sin sesión solo alcanza el portal, DHCP y DNS	Diseño del pipeline (ğ17)
£Qué tasa de reglas por segundo y qué latencia de confirmación soporta el controlador?	Toda orden se confirma por barrera OpenFlow antes de responder; la medición fina es parte de la campaña de pruebas	Implementación del adaptador (ğ11)
£Quién es elegible para perfiles elevados?	Solo la autenticación o una elevación aprobada conceden privilegios; no hay elegibilidad implícita	Política de autorización (ğ7)
£El directorio viaja en claro dentro del segmento?	En el prototipo se acepta y se documenta; en despliegue, cifrado obligatorio	Decisión documentada
£La suplantación de MAC e IP en el mismo puerto es detectable?	No por el pipeline; se declara como limitación conocida y se compensa con la escalera	Análisis de amenazas
£Cómo agregan caminos los switches del núcleo?	Prefijos por switch de acceso en la referencia; caminos individuales en el prototipo	Diseño de enrutamiento
£Clúster del controlador de dos o de tres nodos?	Tres nodos: el consenso exige mayoría, y tres es el mínimo que sobrevive a una caída	Decisión de alta disponibilidad
£Cuántos recursos requiere el despliegue?	14 máquinas virtuales: 21 núcleos, 31 GB de RAM y 145 GB de disco, repartidos por rol	Tabla ğ15
£Quedan inconsistencias con la propuesta presentada?	La propuesta consolidada ya refleja las prioridades y las cookies definitivas	Documento de propuesta

3. Arquitectura interna de los servicios de R1 y R2

Hay un solo punto de decisión —el motor de políticas— y un solo traductor a OpenFlow —el adaptador del controlador—. El resto identifica, aporta atributos o presenta. Los servicios no se llaman entre sí por invocaciones internas: lo síncrono viaja por REST y lo que informa, por el bus

de eventos.

3.1. Portal cautivo

Sin estado propio. Presenta el selector de reino —comunidad, operación o invitado— y reenvía las credenciales al servicio de identidad. El selector *no concede nada*: solo elige la ruta de verificación; un intento de operador con credenciales de comunidad —o al revés— falla en la verificación y queda auditado. La página cautiva es una interfaz sobre su propia API: entrada, registro de invitado, solicitud de elevación y cierre de sesión.

3.2. Servicio de identidad

Dueño de las sesiones y de los repositorios de credenciales de operadores e invitados. Su algoritmo de verificación, reino por reino, está en ğ5; su máquina de estados de sesión, en ğ6.

3.3. Registro de dispositivos

Guarda los equipos habilitados y su historial (altas, revocaciones, movimientos). Su regla de fondo: *registrar no concede confianza* — el registro es un atributo que la política evalúa, jamás un privilegio en sí mismo. Solo los operadores se registran; los usuarios académicos no (mantiene el registro acotado).

3.4. Motor de políticas

El único componente que decide. Evalúa la asignación *rol + permiso + recurso + condiciones* contra la política central (las once condiciones de ğ7) y emite la orden correspondiente: aplicar perfil de sesión, aplicar mitigación o retirar. Toda decisión de mitigación lleva vencimiento obligatorio —ninguna regla de respuesta queda instalada para siempre— y las decisiones de alto impacto exigen aprobación humana previa.

3.5. Adaptador del controlador

Traduce cada orden a reglas OpenFlow concretas. Es el único componente que conoce la sintaxis del controlador; los demás expresan *qué*, nunca *cómo*. Confirma cada instalación con una barrera OpenFlow —la regla está escrita en el switch antes de responder— y retira *siempre por cookie*: nunca toca una regla ajena.

3.6. Consola y Auditoría

La consola es la interfaz del operador: alertas en vivo y aprobaciones. Su sesión es la del propio operador (efecto SSO: una sola autenticación abre lo que el rol permite) y cada petición se valida contra el rol en el servidor. La auditoría escucha el catálogo completo de eventos y registra también los huecos: si un evento llega con número de secuencia saltado, el hueco queda *declarado*, jamás oculto.

4. El algoritmo del login, reino por reino

4.1. Comunidad universitaria (proveedor institucional por RADIUS)

1. La persona elige ńcomunidadż en el selector y envía usuario y contraseña.
2. El portal reenvía las credenciales al servicio de identidad, sin guardarlas.
3. El servicio de identidad, como cliente RADIUS, envía una *petición de acceso* al servidor RADIUS institucional (usuario y contraseña cifrados según el protocolo).

4. El servidor responde *acceso aceptado* o *acceso rechazado*. Con rechazo, el intento queda auditado y termina el flujo.

5. Con aceptación, el servicio abre el registro contable de la sesión (*inicio*) y crea la sesión con perfil académico.

6. La sesión se publica como evento y se ordena al controlador la instalación del perfil (prioridad 200, ğ17).

El prototipo simula al proveedor institucional con un servidor RADIUS propio y un directorio de cuentas de prueba: se simula *al proveedor*, no *al protocolo*.

4.2. Operadores (repositorio propio + TOTP)

1. El aprovisionamiento ocurre antes del primer login: un administrador crea la cuenta (usuario, contraseña con hash bcrypt, rol) y el sistema genera el secreto del segundo factor, mostrado una sola vez como código QR.

2. El operador carga el QR en su aplicación autenticadora y verifica un código; recién entonces el par (dispositivo, operador) queda habilitado.

3. En el login: usuario y contraseña se verifican contra el hash bcrypt —jamás contra un texto en claro—.

4. El código TOTP del momento se verifica contra el secreto. Sin código correcto no hay sesión, y no existe variante sin segundo factor.

5. La sesión se emite con el rol del operador (TI, administrador o superadministrador) y sus relojes más estrictos (ğ6).

4.3. Invitados (registro efímero)

1. El invitado se autoregistra con usuario y contraseña; la cuenta nace con vencimiento a 24 horas.

2. El login verifica contra ese registro como cualquier otro reino.

3. Al vencer el plazo, la cuenta se borra sola — sin intervención administrativa — y los intentos posteriores se rechazan.

El mecanismo completo del reino invitado está fuera del alcance del prototipo; el lugar queda reservado y operativo en lo esencial.

5. La sesión: estados y relojes

Estado	Cómo se entra	Cómo se sale
Activa	Login verificado: sesión emitida con rol, dispositivo y relojes	Cierre explícito · revocación administrativa · inactividad · tope · movimiento del dispositivo
Cerrada	Cualquiera de las salidas anteriores	Terminal; el evento *sesión cerrada* registra el motivo

Los dos relojes, por perfil:

Perfil	Inactividad máxima	Tope absoluto	Sentido
Académico	30 min	12 h	Acompaña la jornada; la inactividad devuelve el equipo al perfil base
Operador (TI, Admin, SA)	15 min	8 h	Más estricto: la sesión abre la red de gestión y la consola
Elevación temporal	según la elevación	1 h por defecto	El tope es parte de la decisión que la concede

La misma cifra vive en dos lugares —la regla del switch y la sesión— y es una sola por perfil: sin desincronización posible. La sesión está además *ligada al dispositivo*: nace atada a la ubicación (MAC, puerto, switch, IP) que el controlador aprendió, y si esa MAC aparece en otro puerto o switch, la sesión se invalida de inmediato. Un cierre explícito no espera a ningún reloj.

6. El motor de políticas y sus condiciones

La política central define 4 roles, 37 permisos y 78 asignaciones. Cada asignación dice: *este rol, sobre este permiso, para estos recursos, si se cumplen estas condiciones, con estas obligaciones* (auditar, notificar, justificar, registrar). Las once condiciones son la letra fina del ńquién puede quéż:

Cond.	Nombre	Qué exige
C1	Ámbito	El recurso pertenece al ámbito asignado al rol
C2	Delegación vigente	Existe una delegación explícita, con alcance y vencimiento
C3	Rango aprobado	El valor o la acción está dentro del rango aprobado
C4	Separación de funciones	El solicitante es distinto del aprobador
C5	Sesión privilegiada	Segundo factor verificado, dispositivo registrado y canal de gestión
C6	Estado de seguridad	Sin compromiso, cuarentena ni incidente que impida la acción
C7	Bajo impacto	La severidad no supera el umbral; si lo supera, se exige aprobación
C8	Sesión propia	El sujeto solo opera sus propias sesiones
C9	Recurso autorizado	El tipo y la instancia del recurso están en la lista del rol
C10	Contexto permitido	Ventana de mantenimiento o emergencia declarada y ubicación permitida
C11	Solo lectura	El rol consulta y ejecuta operaciones autorizadas, no configura

Reglas transversales que nadie puede violar: nadie aprueba su propia solicitud; nadie se asigna un rol a sí mismo; la combinación de roles no supera el mayor privilegio (la delegación es la única vía de ampliación); solo el superadministrador delega; y la auditoría nunca la administra quien opera. La política es un documento único, validado automáticamente: toda referencia cruzada (rol, permiso, condición, recurso) se comprueba en cada cambio, y su vista de matriz se regenera de la misma fuente.

7. Modelo de datos

Estructura	Campos	Notas
Sesión	identificador opaco · identidad · rol o perfil · MAC · puerto · switch · IP · inactividad máxima · tope absoluto	Vive en el servicio de identidad; el retiro es inmediato
Operador	usuario · hash bcrypt · secreto TOTP · rol	Creado por la cadena SA*ightarrow*Admin*ightarrow*TI; el secreto se muestra una vez
Invitado	usuario · hash bcrypt · vencimiento	Se borra solo al vencer (24 h)
Dispositivo registrado	MAC · titular · rol · responsable · vigencia · historial	Registrar no concede confianza
Decisión de política	incidente · acción · parámetros (tasa, TTL) · resultado	Toda mitigación expira sola
Evento	identificador único · tipo · emisor · marca de tiempo · secuencia · correlación · contenido	La envoltura es común a los dieciséis tipos del catálogo

8. Contratos de interfaz, campo a campo

8.1. Órdenes al controlador (northbound)

Tres órdenes, un mismo recurso, confirmación en dos niveles (aplicada + verificación diferida):

Orden	Campos	Semántica
Aplicar perfil	dispositivo (MAC, switch, puerto) · vigencia (inactividad y tope) · contexto (cookie, solicitante, motivo) · perfil	Instala la sesión con prioridad 200; la vigencia es la misma cifra en la regla y en la sesión
Aplicar mitigación	acción (limitar, bloquear origen, aislar, cuarentena) · objetivo · orígenes · parámetros (tasa, TTL) · contexto (cookie, incidente, solicitante, aprobación)	Instala la respuesta con prioridad 1000 y vencimiento = TTL; la cuarentena se rechaza sin aprobación
Retirar	contexto (cookie)	Retiro por cookie, siempre; responde al confirmar

Reglas de las órdenes: la cookie es la clave de idempotencia (reaplicar la misma cookie no duplica reglas); ante un controlador que no responde, el solicitante reintenta *la misma orden*; los errores

son estructurados (400 esquema inválido, 401 sin clave, 403 fuera de competencia, 404 desconocido, 409 duplicado, 503 no disponible).

8.2. Eventos del bus

Todo evento viaja con la misma envoltura: identificador único (clave de idempotencia), tipo, emisor, marca de tiempo, secuencia por incidente y claves de correlación. El contenido es propio de cada tipo:

Evento	**Campos del contenido**	**Quién produce *ightarrow* quién consume**
Sesión abierta	identidad · rol o perfil · dispositivo · marca de tiempo	Identidad *ightarrow* políticas, auditoría
Sesión cerrada	identidad · rol o perfil · dispositivo · motivo	Identidad *ightarrow* políticas, auditoría
Dispositivo registrado / revocado	MAC · titular · rol · responsable · vigencia	Registro *ightarrow* auditoría, consola
Solicitud de elevación	solicitante · perfil pedido · alcance · duración	Portal *ightarrow* políticas, consola, auditoría
Mitigación requerida	incidente · acción · objetivo · orígenes · parámetros · TTL	Políticas *ightarrow* comando al controlador; eco al bus
Mitigación aplicada	incidente · reglas · switches · marca de tiempo	Controlador *ightarrow* monitor, incidentes, auditoría
Mitigación verificada	incidente · tasas antes/después · cumple objetivo	Monitor *ightarrow* incidentes, políticas, auditoría
Mitigación expirada	incidente · regla · motivo	Monitor/controlador *ightarrow* incidentes, políticas, auditoría

La regla de fondo del bus: **el evento informa; el comando ejecuta**. Las decisiones que deben aplicarse con confirmación viajan como comandos por la API del controlador y publican su eco por el bus para que la auditoría y la consola las vean. Nunca viajan credenciales, ni en el contenido ni en la correlación. La entrega es al menos una vez, con idempotencia por identificador y orden por incidente; lo que no se procesa tras cinco reintentos queda en una cola de no entregados, visible y auditada.

9. El pipeline del switch

La regla es la unidad de política materializada: cada entrada del switch es una decisión convertida en coincidencia y acción. El orden de evaluación es una jerarquía de autoridad —a mayor prioridad, mayor poder de decidir sobre el paquete— y es el mismo en toda la red:

Prior.	**Entrada**	**Acción**	**Cookie**	**Vigencia**
1000	Mitigación (limitar tasa)	medidor con banda de descarte, luego caminos	incidente	TTL de la mitigación
1000	Mitigación (bloquear origen / aislar / cuarentena)	descarte	incidente	TTL corto o de la aprobación

200	Sesión de perfil	hacia el alcance del perfil	sesión	inactividad y tope de la sesión
200	Elevación	hacia el alcance elevado	sesión temporal	TTL de la elevación
150	Portal (pre-login)	hacia el portal	esqueleto	permanente
120	Par MAC/IP aprendido	hacia caminos	esqueleto	permanente
110	Anti-suplantación (IP con MAC ajena)	descarte	esqueleto	permanente
100	Destino a la red de gestión	descarte	esqueleto	permanente
20	Caminos	puerto calculado	camino	mientras valga la topología
10	DHCP y DNS	hacia caminos	esqueleto	permanente
—	Sin coincidencia	paquete al controlador (aprendizaje)	—	—

Tres lecturas de esta tabla, para que quede clara la jerarquía:

- **La mitigación manda sobre todo** — es la respuesta al ataque y no puede ser vencida por una sesión. **La sesión manda sobre el esqueleto** — es el privilegio otorgado. **El esqueleto manda sobre los caminos** — es la línea base de cualquier dispositivo, autenticado o no.
- **El esqueleto (prioridades 150 a 10) es la lista cerrada** que todo dispositivo lleva antes de autenticarse: portal, par MAC/IP, anti-suplantación, denegación a la gestión y DHCP/DNS. La sesión no lo reemplaza: convive con él y lo vence por prioridad. El descarte hacia la red de gestión es permanente — una sesión académica jamás lo abre.
- **El modo de fallo es seguro.** Si el controlador deja de responder, las entradas instaladas permanecen y un paquete sin coincidencia se descarta: el switch no vuelve a conmutación normal ni inunda. La red no se abre por la caída del controlador; se degrada a la última política conocida. El clúster de tres nodos cubre la continuidad del control; el modo seguro cubre el intervalo.

Las cookies codifican tipo y correlativo en 64 bits: los bits altos distinguen sesión, incidente, esqueleto y camino. El controlador mantiene el registro entre la clave legible y el valor, y el retiro es siempre por cookie, en todas las tablas: nada queda pegado.

9.1. Ejemplo con números: una docente en el puerto p20

Una docente conecta su equipo en el puerto p20 del switch de acceso A1. Sucede, en orden:

1. **Aprendizaje (una sola vez).** El primer paquete no coincide con nada y sube al controlador, que aprende el par (MAC, IP) y su ubicación (A1, p20). Desde ese momento, las entradas proactivas gobiernan: el equipo alcanza el portal (150), recibe DHCP y DNS (10), su tráfico con otra MAC es descartado (110) y todo destino hacia la red de gestión es descartado (100).
2. **Login.** La docente entra al portal y se autentica contra el proveedor institucional. El servicio de identidad emite su sesión con perfil académico (inactividad 30 min, tope 12 h).
3. **Instalación de la sesión.** Llega la orden al controlador: instalar en A1 la regla de prioridad 200 para (MAC, IP) con cookie de sesión y vigencia igual a la sesión. Desde ahora, el tráfico de la docente hacia los servicios de la comunidad e Internet pasa por la prioridad 200.

4. **La escalera decide.** Un paquete hacia la gestión sigue cayendo en el descarte de prioridad 100 — la sesión no lo abre. Un paquete hacia un servicio académico coincide con la sesión (200) y sigue a los caminos (20). Si mañana hubiera una mitigación contra su equipo, la prioridad 1000 vencería a la sesión.

5. **Cierre.** Al cerrar sesión —o al vencer un reloj—, el retiro es por cookie: solo las reglas de esa sesión desaparecen; el esqueleto permanece.

10. El adaptador del controlador por dentro

El adaptador es el único componente que conoce la sintaxis del controlador. Su interior:

Pieza	**Qué hace, en detalle**
Registro de cookies	Traduce cada clave legible (sesión, incidente) a su cookie de 64 bits: los bits altos distinguen el tipo (0x01 sesión, 0x02 incidente, 0x03 esqueleto, 0x04 camino) y el resto es correlativo. El retiro se hace siempre por esta vía: se recorren las reglas del switch y solo se retiran las que llevan la cookie propia
Aplicar mitigación	Por acción, construye la regla: *limitar tasa* instala primero un medidor (unidad: paquetes por segundo, banda de descarte a la tasa de la decisión) y luego la regla de prioridad 1000 que casa origen, puerto y destino y aplica el medidor antes de los caminos; *bloquear origen*, *aislar* y *cuarentena* instalan la regla de prioridad 1000 con acción de descarte. Todas llevan vencimiento igual al TTL de la decisión. Si el origen no está identificado, solo se permite la limitación por destino —aplicada en todos los bordes—; bloquear sin origen se rechaza: bloquearía todo el borde
Aplicar perfil	Regla de prioridad 200 que casa el puerto y la MAC del dispositivo y entrega al camino; lleva los dos relojes de la sesión (inactividad y tope) con la misma cifra que la sesión
Confirmación	Cada instalación se confirma con una barrera OpenFlow: la orden responde *aplicada* con las reglas creadas y la marca de tiempo, y la verificación (si aplica) queda pendiente para el monitor
Consultas	Asociación vigente (MAC, puerto, switch, IP) desde los anfitriones conocidos; reglas instaladas por cookie; topología y contadores del controlador; e inventario de servicios declarados

11. La matriz de acceso: perfiles y recursos

El plano de red se gobierna por perfiles. La escalera de perfiles, con su prioridad y su alcance:

Perfil	**Prior.**	**Cuándo**	**Alcance**
BASE	150/10	Siempre (pre-login)	Portal, DHCP y DNS — la lista cerrada

ACADÉMICO	190	Tras login de comunidad	Servicios de la comunidad e Internet
OPERADOR_TI	200	Tras login de operador	Consola y API de seguridad
OPERADOR_ADMIN	200	Tras login de administrador	Red de gestión
OPERADOR_SA	200	Tras login de superadministrador	Red de gestión y acceso remoto
ELEVACIÓN	200	Aprobada, con vencimiento	Según la instancia (p. ej., laboratorio)

La matriz perfil × recurso resultante (plano de red):

Recurso	**BASE**	**ACAD.**	**OP. TI**	**OP. ADMIN**	**OP. SA**
Portal	SÍ	SÍ	SÍ	SÍ	SÍ
DHCP y DNS	SÍ	SÍ	SÍ	SÍ	SÍ
Servicios de la comunidad	—	SÍ	SÍ	SÍ	SÍ
Internet	—	SÍ	SÍ	SÍ	SÍ
Consola	—	—	SÍ	SÍ	SÍ
API de seguridad	—	—	SÍ	SÍ	SÍ
API de red	—	—	—	SÍ	SÍ
Red de gestión	—	—	—	SÍ	SÍ
Acceso remoto	—	—	—	—	SÍ
Laboratorio (elevación)	—	—	—	—	—

La columna de laboratorio es intencionalmente vacía: el laboratorio no es un perfil fijo, es una instancia de elevación con su solicitante, su alcance y su vencimiento. En el plano de servicios, la matriz equivalente es la de las 78 asignaciones rol × permiso de la política (ğ7); aquí se muestra el plano de red, que es el que el switch materializa.

12. Los endpoints del portal (I3), campo a campo

Recurso	**Método**	**Campos de entrada**	**Respuesta**	**Errores**
/login	GET	—	Selector con las tres poblaciones	—
/login	POST	población · usuario · contraseña · TOTP (operación)	Sesión {identificador, perfil}	401, 503
/logout	POST	identificador de sesión	{estado: cerrada}	404, 503
/guest-register	POST	usuario · contraseña	{estado, vencimiento}	503
/elevation	GET	—	Alcances disponibles	—
/elevation	POST	solicitante · alcance · duración	202 {estado, identificador de evento}	503

Reglas del portal: la contraseña nunca se guarda ni se registra; la población elegida es un dato de auditoría del intento; un intento con credenciales en la ruta equivocada falla y queda auditado.

13. Los endpoints de administración (I7), campo a campo

Cada servicio expone su administración; la consola la agrega y la sesión del operador es la autenticación única. Cada petición se valida contra la sesión *y* el rol en el servidor:

Servicio	**Recurso**	**Método**	**Rol mínimo (permiso)**
Identidad	/sessions/{id}	GET · DELETE	TI (sesiones propias o administrativas)
Identidad	/operators	POST	Administrador (cuentas privilegiadas)
Registro	/devices · /devices/{mac}/history	GET · POST	TI / Administrador
Políticas	/profiles	GET · PUT	PUT: Administrador (P17)
Políticas	/thresholds	GET · PUT	PUT: TI / Admin / SA (P33)
Políticas	/elevations	GET	TI / Administrador
Auditoría	/events (desde, actor, cursor)	GET	Solo lectura
Monitor	/metrics · /baselines	GET	Solo lectura
Consola	/alerts	GET	TI / Admin / SA (P09)

Convenciones comunes: respuesta {datos, error{código, mensaje}}; paginación por cursor; 401 sin sesión válida, 403 con sesión sin el rol. Quien cambia perfiles o umbrales queda registrado con su identidad.

14. Configuración de RADIUS y LDAP

El servicio de identidad es cliente RADIUS del proveedor institucional. La configuración del prototipo:

Parámetro	**Valor y sentido**
Servidor RADIUS	El servidor del prototipo (simula al proveedor institucional; en despliegue, el institucional)
Secreto compartido	Clave entre el cliente (identidad) y el servidor; jamás en claro en configuraciones versionadas
Red de clientes autorizados	10.0.0.0/24: solo la identidad puede consultar
Contabilidad	Identificador contable único por sesión; *inicio* al abrir, *intermedio* periódico y *fin* al cerrar — alimenta la correlación de la auditoría
Directorio detrás de RADIUS	Cuentas de prueba del proveedor simulado; el prototipo simula al proveedor, no al protocolo
Transporte	Prototipo: 1812/1813 y directorio en claro, documentado; despliegue: cifrado obligatorio

15. Secuencia: el esqueleto al conectar (proactivo)

Lo que ocurre cuando un switch se incorpora — sin que ningún paquete de usuario haya aparecido todavía:

1. El switch se conecta al controlador y negocia OpenFlow 1.3; el controlador confirma sus capacidades (254 tablas, medidores, grupos).
2. El controlador instala de inmediato el esqueleto estático: portal (150), denegación a la gestión (100), DHCP/DNS (10) y los caminos conocidos (20). Nada de esto espera a un usuario.
3. Llega el primer paquete de un dispositivo nuevo: sin coincidencia, sube al controlador — es la única vez.
4. El controlador aprende el par (MAC, IP) y su ubicación, y completa el esqueleto: par MAC/IP (120) y anti-suplantación (110).
5. Desde ese instante, todo el tráfico del dispositivo coincide con reglas proactivas; el controlador no vuelve a estar en el camino.

16. Secuencia: la mitigación completa

El caso de ataque más simple — una inundación de paquetes hacia un servicio — de punta a punta:

1. El sensor conectado al espejo agrega el tráfico por destino y ventana, y publica muestras.
2. El monitor recibe las muestras y las publica para la detección.
3. La detección compara contra la línea base del destino: la desviación supera el umbral y publica una anomalía con su severidad propuesta.
4. El gestor de incidentes abre el incidente y lo publica.
5. El motor de políticas evalúa el incidente y decide: limitar la tasa del origen a 1000 paquetes por segundo, con vencimiento de 300 segundos.
6. La decisión viaja como orden al adaptador (por la API del controlador); su eco queda en el bus para auditoría y consola.
7. El adaptador instala el medidor y la regla de prioridad 1000, y confirma con barrera.
8. El evento *mitigación aplicada* se publica con las reglas instaladas.
9. El monitor compara las tasas antes y después y publica *mitigación verificada* (cumple o no el objetivo).
10. Al vencer los 300 segundos, la regla expira sola — o se retira antes por cookie — y el hecho se publica.
11. La auditoría registró cada paso, con su secuencia por incidente y sus huecos declarados si los hubo.

17. La elevación temporal

El académico puede necesitar, por una práctica de laboratorio, un alcance que su perfil no tiene. El flujo completo:

1. El académico solicita la elevación por el portal: alcance y duración.
2. La solicitud se publica como evento; las políticas la registran como pendiente.
3. Un aprobador (distinto del solicitante — condición C4) la aprueba; la aprobación queda vinculada a la solicitud y auditada.
4. El controlador instala la regla de elevación con prioridad 200 y vencimiento igual al concedido (1 hora por defecto).
5. Al vencer —o al retirarse—, el retiro por cookie devuelve al equipo a su perfil académico, sin intervención.

La elevación es una sesión temporal, no un rol nuevo: comparte cookie de sesión, prioridad y relojes; cambia el alcance y el tope.

18. Secuencia completa con protocolo por salto

El caso de uso completo —conexión y login de un académico— con los mensajes exactos entre componentes:

Paso	**Qué ocurre**	**Mensaje**	**Entre**
1	El equipo envía su primer paquete	Sin coincidencia *ightarrow* paquete al controlador	Switch *ightarrow* Controlador (OpenFlow)
2	El controlador aprende (MAC, IP) y ubicación, e instala el esqueleto	Reglas 150/120/110/100/10	Controlador *ightarrow* Switch
3	La persona abre el portal y elige su reino	Formulario de credenciales	Persona *ightarrow* Portal (HTTPS)
4	El portal reenvía las credenciales	Verificación	Portal *ightarrow* Identidad (REST)
5	La identidad consulta al proveedor institucional	Petición de acceso RADIUS	Identidad *ightarrow* RADIUS (UDP)
6	El proveedor responde	Acceso aceptado	RADIUS *ightarrow* Identidad
7	La identidad crea la sesión y la publica	Evento *sesión abierta*	Identidad *ightarrow* Bus (AMQP)
8	La identidad ordena el perfil	Aplicar perfil (cookie de sesión)	Identidad *ightarrow* Controlador (REST)
9	El controlador instala y confirma	Regla de prioridad 200 + barrera	Controlador *ightarrow* Switch
10	El equipo navega por su alcance	Coincidencia en 200 *ightarrow* caminos	Switch *ightarrow* Switch (plano de datos)
11	La auditoría registra cada paso	Eventos recibidos del catálogo	Bus *ightarrow* Auditoría

El mismo patrón —identificar, decidir, traducir, ejecutar, registrar— se repite para la mitigación y para la elevación; lo único que cambia es quién dispara el primer paso.

19. El bus: colas y enlaces

Cada servicio consumidor tiene su cola propia, duradera, con sus enlaces al catálogo:

Consumidor	Enlaces (tipos de evento)	Propósito
Auditoría	El catálogo completo	Registro total, sin excepción
Monitor	Dispositivo conectado · mitigación aplicada	Ubicaciones y verificación
Detección	Muestra de métricas	La materia prima de la línea base
Incidentes	Anomalía · verificación · expiración · dispositivo movido	Ciclo de vida del incidente
Políticas	Incidente abierto · verificación · expiración · elevación · dispositivo movido	Decisión y seguimiento
Identidad	Dispositivo movido	Invalidación de la sesión ligada
Registro	Dispositivo conectado	Historial por ubicación
Consola	Anomalía · incidente abierto · altas y bajas de dispositivos	Alertas en vivo

Además, cada incidente abre su **cola propia**, declarada al abrirse y auto-borrada al cerrarse (con respaldo de 24 horas): es el mecanismo de entrega ordenada — una sola cola, orden FIFO, sin reordenamiento en el consumidor. Los parámetros de entrega: confirmación de publicación activada; acuse manual tras procesar; cinco reintentos y luego cola de no entregados, visible y auditada; ventana de duplicados de 7 días por identificador; y un salto de secuencia se espera un instante y, si no llega, se declara el hueco — jamás se procesa fuera de orden ni se oculta.

20. Funciones internas de los servicios

Las piezas internas que sostienen las secciones anteriores, servicio por servicio:

Servicio	Función	Qué hace
Identidad	registrar_operador	Crea la credencial (hash bcrypt) y el secreto TOTP; devuelve la URI del código QR, que se muestra una sola vez
Identidad	registrar_invitado	Crea la cuenta efímera con su vencimiento
Identidad	verificar	Despacha por reino: RADIUS, repositorio propio con TOTP, o registro efímero
Identidad	emitir_sesión	Crea la sesión con los relojes del perfil y publica el evento
Identidad	sesión_válida	Aplica inactividad y tope al consultar; cierra y publica al vencer
Identidad	manejar_evento	Un dispositivo movido invalida sus sesiones al instante
Identidad	purgar_invitados	Bucle que borra las cuentas vencidas

Motor	decidir	Incidente abierto *ightarrow* acción y parámetros (tasa, TTL) según la política
Motor	enviar_orden	La orden viaja al controlador; el eco queda en el bus
Adaptador	cookie_hex	Clave legible *ightarrow* cookie de 64 bits con su tipo en los bits altos
Adaptador	aplicar_mitigación	Medidor y regla 1000 según la acción; rechaza bloquear sin origen
Adaptador	aplicar_perfil	Regla 200 con los dos relojes de la sesión
Adaptador	retirar	Elimina solo las reglas de la cookie propia

El invariante del retiro, en pseudocódigo:

```
retirar(orden):
    cookie = registro_cookies[orden.contexto.cookie]
    si cookie no existe:
        responder 404 (cookie desconocida)
    para cada switch de la red:
        para cada regla instalada en el switch:
            si regla.cookie == cookie:
                eliminar regla
    responder retirada confirmada
```

Ninguna otra función del sistema toca reglas ajenas: el retiro por cookie es la única vía, en todas las tablas.

21. Análisis cuantitativo de R1 — control de acceso según rol

Qué se mide	**Cifra**	**Cómo se obtuvo**
Roles definidos en la política	4	académico · especialista de TI · administrador de red · superadministrador
Permisos y condiciones del modelo	37 permisos · 11 condiciones	Catálogo de la política, validado automáticamente
Asignaciones rol × permiso	78	Matriz generada y verificada contra su fuente
Reinos de identidad	3	comunidad (RADIUS) · operadores (bcrypt + TOTP) · invitados (TTL 24 h)
Entradas del perfil base por dispositivo	6	las cinco de la escalera más el aprendizaje
Sesión académica	30 min de inactividad · 12 h de tope	Valor inicial de diseño; se mide en campaña

Sesión de operador	15 min de inactividad · 8 h de tope	Más estricta: abre la gestión y la consola
Cookie de sesión y de incidente	bits altos 0x01 y 0x02	Convención fija del diseño
Casos automatizados del módulo de identidad	21	Suite de pruebas en verde (verificación continua)

Qué significa cada cifra, en una frase: cuatro roles bastan porque el privilegio fino sale de la combinación *rol + recurso + condición*, no de más roles; setenta y ocho asignaciones cubren los treinta y siete permisos sin redundancias; los tres reinos garantizan que una cuenta de administrador nunca sea la misma que la de alumno; y los dos relojes por sesión aseguran que ningún privilegio quede abierto más de lo necesario.

22. Análisis cuantitativo de R2 — protección de recursos privilegiados

Qué se mide	**Cifra**	**Cómo se obtuvo**
Tipos de recurso catalogados	50+	El catálogo distingue servicios, recursos, cuentas, red y dispositivos
Clases mínimas de clasificación	3	generales · privilegiados · críticos
Denegación a la gestión desde el perfil base	descarte en prioridad 100	Entrada permanente; ninguna sesión la abre
Cadena de cuentas privilegiadas	SA *ightarrow* Admin *ightarrow* TI	Delegación vigente, con responsable y vencimiento
Aprobación de alto impacto	obligatoria para cuarentena	Sin aprobación, la orden se rechaza en el controlador
Registro de dispositivos privilegiados	acotado	Solo operadores; los académicos no se registran
Accesos registrados	100 %	La auditoría escucha el catálogo completo
Retiro de reglas	siempre por cookie	Probado: una cookie ajena jamás se toca

La traducción de la decisión a regla SDN quedó implementada y verificada: la mitigación se instala con prioridad 1000 y vencimiento igual a su TTL —toda respuesta expira sola—, la sesión con prioridad 200, y el retiro por cookie está probado por caso automatizado. La clasificación del recurso decide qué condiciones lo protegen: un recurso crítico exige ventana de mantenimiento o emergencia declarada para su configuración.

23. Análisis cuantitativo de RE — eficiencia

RE agrupa rendimiento, latencia, escalabilidad y continuidad. Las cifras consolidadas:

Presupuesto	Cifra	Cómo se verifica
Entradas de flujo en la red (10 switches)	420–520 nominales · 665 peor caso	Presupuesto por componente; el llenado real se mide hasta agotar la tabla
Conmutación ante caída de enlace	grupo de respaldo o reinstalación	Se mide el tiempo en la campaña de pruebas
Confirmación de orden	barrera OpenFlow	La orden responde con la regla ya escrita
Reintento ante controlador caído	la misma orden, sin límite	Idempotencia por cookie
Bus: confirmación de publicación	activada	El emisor sabe que el mensaje fue recibido
Bus: reintentos y cola de no entregados	5 reintentos · cola por servicio	Lo no procesado queda visible y auditado
Ventana de duplicados	7 días por identificador	Idempotencia del consumidor

Recursos del despliegue —el techo físico de RE en el prototipo—, 14 máquinas virtuales:

Conjunto	Núcleos	RAM	Disco
4 switches virtuales	4	4 GB	32 GB
3 controladores (clúster)	6	6 GB	30 GB
4 servidores de plataforma	8	18 GB	59 GB
3 equipos de prueba	3	3 GB	24 GB
Total	**21**	**31 GB**	**145 GB**

Peso en disco de los componentes de terceros tras su instalación: controlador SDN 559 MB, base de datos 158 MB, sensor de tráfico 135 MB, visualización 117 MB, bus 112 MB, métricas 102 MB, autenticación RADIUS 87 MB, directorio 87 MB; los once servicios propios rondan los 200 MB cada uno. El disco es la restricción dominante, y por eso las imágenes viajan empaquetadas, se cargan y se borran de cada máquina.

24. Contraste con el avance previo y ajustes justificados

El avance anterior declaró explícitamente no contener mediciones; esta consolidación cierra esa deuda y corrige lo que la evidencia corrigió:

Supuesto del avance previo	Estado consolidado	Justificación
Diez switches dedicados	Cuatro switches virtuales (mínimo tres)	Los recursos entregados son 14 máquinas; se conserva núcleo dual y acceso con doble enlace
Memoria TCAM sin verificar	Sin TCAM: conmutación por software	La sonda lo confirmó; el límite se mide por llenado
Espejo de tráfico en el acceso	Espejo en el núcleo, entrega por confirmar	El núcleo ve el tráfico que interesa a la detección; hay respaldo fijado

Red de gestión numerada con .0	VLAN 100 = 10.0.0.0/24, canon 10/20/30/100	Reordenamiento cerrado en equipo
Múltiples tablas en duda	254 tablas confirmadas	Sonda directa
Clúster de dos o tres nodos	Tres nodos	El consenso exige mayoría
Servicios ńpor diseñarż	Once servicios construidos y probados	186 casos automatizados en verde

25. Cumplimiento de R1, R2 y RE

Requisito	**Dónde se cumple**	**Evidencia**
R1.1–R1.3	Identificación por MAC y contexto; autenticación por reino; perfil por defecto y elevado	Portal + identidad; sesiones con perfil y casos automatizados
R1.4–R1.6	Política contextual y traducción a reglas; mínimo privilegio; denegación	37 permisos, 78 asignaciones, descarte a gestión, denegación por defecto
R1.7–R1.8	Gestión de roles, perfiles y dispositivos; rol administrativo restringido	Cadena SA$ightarrow$Admin$ightarrow$TI; segundo factor obligatorio
R1.9–R1.10	Trazabilidad y crecimiento acotado	Auditoría completa; registro solo privilegiado
R2.1–R2.9	Inventario, clasificación, políticas, segmentación, actualización y auditoría	Catálogo de 50+ tipos, tres clases, descarte a gestión, aprobación de alto impacto
R2.10	Traducción de decisión a regla SDN	Adaptador: prioridades 1000/200, cookies, retiro por cookie
RE	Rendimiento, latencia, escalabilidad y continuidad	Presupuestos y recursos de ğ24; medición fina en campaña

26. Declaración de uso de inteligencia artificial

Conforme a los lineamientos del curso, el Grupo 3 declara que usó inteligencia artificial generativa (Claude, de Anthropic, a través de Claude Code) para consolidar el diseño con la implementación, extraer las cifras cuantitativas de las evidencias de laboratorio y redactar este documento. Las decisiones de diseño, la interpretación de los resultados y la responsabilidad por el contenido son del equipo, que revisó y valida cada cifra aquí presentada.